

# 모의 침투 테스트 보고서

대상: 직접 제작한 취약 웹 사이트 (PHP + MySQL)

작성일: 2026년 7월

## 차 례

|                                             |   |
|---------------------------------------------|---|
| 1. 개요 .....                                 | 3 |
| 2. 테스트 환경 .....                             | 3 |
| 3. 취약점 점검 결과 .....                          | 3 |
| 3.1 코드 인젝션 (Code Injection) .....           | 3 |
| 3.2 SQL 인젝션 (SQL Injection) .....           | 4 |
| 3.3 크로스사이트스크립트 (XSS) .....                  | 4 |
| 3.4 크로스사이트요청위조 (CSRF) .....                 | 5 |
| 3.5 악성 파일 업로드 (Malicious File Upload) ..... | 5 |
| 4. 취약점 종합 요약 .....                          | 5 |
| 5. 결론 및 권고사항 .....                          | 6 |

## 1. 개요

본 보고서는 직접 제작한 PHP + MySQL 기반 취약 웹 애플리케이션에 대해 수행한 모의 침투 테스트 결과를 기록한 문서입니다. 주요정보통신기반시설 취약점 분석·평가 기준에 준하여 취약점을 점검하고 각 항목에 대한 현황 및 대응 방안을 제시합니다.

## 2. 테스트 환경

| 항목     | 내용                                 |
|--------|------------------------------------|
| 서버 환경  | Windows + XAMPP (PHP, MySQL)       |
| 애플리케이션 | 회원가입/로그인, 게시판, 검색, 파일 업로드, ping 기능 |
| 테스트 도구 | Burp Suite, SQLMap, 웹 브라우저         |
| 점검 기준  | 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드  |

## 3. 취약점 점검 결과

### 3.1 코드 인젝션 (Code Injection)

| 항목                                                                                                                                                                                                              | 내용                                                       |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| 분류                                                                                                                                                                                                              | 웹 애플리케이션 취약점                                             |
| 점검 항목                                                                                                                                                                                                           | 코드 인젝션 (OS Command Injection)                            |
| 점검 결과                                                                                                                                                                                                           | 취약                                                       |
| 취약 경로                                                                                                                                                                                                           | ping.php                                                 |
| 취약 내용                                                                                                                                                                                                           | IP 입력값을 OS 명령어에 직접 삽입. 파이프( ) 구분자로 임의 명령어 실행 가능          |
| 확인 방법                                                                                                                                                                                                           | 127.0.0.1   whoami 입력 후 서버 계정 정보 출력 확인                   |
| 대응 방안                                                                                                                                                                                                           | escapshellcmd(), escapshellarg() 사용, 화이트리스트(IP 형식) 기반 검증 |
| <b>▶ 대응 이유:</b> 네트워크 확인 기능의 입력란에 IP 주소 대신 명령어를 함께 입력합니다. 서버는 네트워크 확인을 하면서 동시에 입력된 명령어도 실행합니다. 공격자는 이 방식으로 서버에 저장된 파일 목록 조회, 사용자 비밀번호 파일 열람, 공격자 컴퓨터로 서버를 원격 연결하는 것까지 가능합니다. 웹 입력란이 서버를 직접 조종하는 리모컨이 되어버린 상황입니다. |                                                          |

### 3.2 SQL 인젝션 (SQL Injection)

| 항목                                                                                                                                                                                                                                               | 내용                                                             |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------|
| 분류                                                                                                                                                                                                                                               | 웹 애플리케이션 취약점                                                   |
| 점검 항목                                                                                                                                                                                                                                            | SQL 인젝션 (SQL Injection)                                        |
| 점검 결과                                                                                                                                                                                                                                            | 취약                                                             |
| 취약 경로                                                                                                                                                                                                                                            | login.php, post.php?id=, search.php                            |
| 취약 내용                                                                                                                                                                                                                                            | 사용자 입력값을 검증 없이 SQL 쿼리에 직접 삽입하여 로그인 우회 및 DB 데이터 탈취 가능           |
| 확인 방법                                                                                                                                                                                                                                            | 로그인 폼에 admin' OR '1'='1 입력 후 우회 확인, UNION SELECT로 users 테이블 추출 |
| 대응 방안                                                                                                                                                                                                                                            | PDO Prepared Statement 또는 파라미터화된 쿼리 사용, 특수문자 필터링 적용            |
| <p>▶ <b>대응 이유:</b> 공격자가 로그인 화면의 아이디 입력란에 특수 문자를 포함한 문장을 입력합니다. 서버는 이것을 정상 데이터가 아닌 SQL 명령어로 해석하여, 비밀번호 확인 없이 관리자 계정으로 로그인을 허용합니다. 마치 금고 잠금 장치에 특정 신호를 보냈더니 비밀번호 없이 열리는 것과 같습니다. 더 나아가 게시글 번호 자리에 특수 명령어를 넣으면 회원 전체의 아이디와 비밀번호가 화면에 그대로 출력됩니다.</p> |                                                                |

### 3.3 크로스사이트스크립트 (XSS)

| 항목                                                                                                                                                                                                                       | 내용                                                        |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|
| 분류                                                                                                                                                                                                                       | 웹 애플리케이션 취약점                                              |
| 점검 항목                                                                                                                                                                                                                    | 크로스사이트스크립트 (XSS)                                          |
| 점검 결과                                                                                                                                                                                                                    | 취약                                                        |
| 취약 경로                                                                                                                                                                                                                    | board.php (Stored XSS), search.php (Reflected XSS)        |
| 취약 내용                                                                                                                                                                                                                    | 사용자 입력값이 HTML로 그대로 출력되어 악성 스크립트 실행 가능                     |
| 확인 방법                                                                                                                                                                                                                    | <script>console.log(document.cookie)</script> 삽입 후 실행 확인  |
| 대응 방안                                                                                                                                                                                                                    | 출력 시 htmlspecialchars() 적용, Content-Security-Policy 헤더 설정 |
| <p>▶ <b>대응 이유:</b> 공격자가 게시판에 일반 글처럼 보이지만 악성 코드가 숨겨진 글을 작성합니다. 다른 사용자가 그 글을 읽는 순간, 아무것도 클릭하거나 다운로드하지 않았는데도 해당 사용자의 로그인 정보가 공격자 서버로 몰래 전송됩니다. 공지사항으로 위장한 글 하나로 수백 명의 계정이 동시에 탈취될 수 있으며, 피해자는 자신이 공격받았다는 사실조차 알 수 없습니다.</p> |                                                           |

### 3.4 크로스사이트요청위조 (CSRF)

| 항목                                                                                                                                                                                                           | 내용                                                |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| 분류                                                                                                                                                                                                           | 웹 애플리케이션 취약점                                      |
| 점검 항목                                                                                                                                                                                                        | 크로스사이트요청위조 (CSRF)                                 |
| 점검 결과                                                                                                                                                                                                        | 취약                                                |
| 취약 경로                                                                                                                                                                                                        | mypage.php (개인정보 수정)                              |
| 취약 내용                                                                                                                                                                                                        | CSRF 토큰 없이 상태 변경 요청 처리. 외부에서 사용자 정보 변경 가능         |
| 확인 방법                                                                                                                                                                                                        | 외부 사이트 자동 제출 폼으로 개인정보 변경 요청 전송 후 반영 확인            |
| 대응 방안                                                                                                                                                                                                        | CSRF 토큰 생성 및 서버 측 검증 적용, SameSite=Strict 쿠키 속성 설정 |
| <p>▶ 대응 이유: 사용자가 로그인한 상태에서 공격자가 보낸 낯시 링크를 클릭합니다. 사용자는 단순히 링크를 눌렀을 뿐인데, 뒤에서 비밀번호 변경 요청이 서버에 자동으로 전송됩니다. 서버는 이것이 사용자 본인의 정상 요청이라고 판단하고 비밀번호를 변경합니다. 이후 공격자는 새 비밀번호로 피해자 계정에 로그인하며, 피해자는 자신의 계정에서 쫓겨나게 됩니다.</p> |                                                   |

### 3.5 악성 파일 업로드 (Malicious File Upload)

| 항목                                                                                                                                                                                                                         | 내용                                                                    |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| 분류                                                                                                                                                                                                                         | 웹 애플리케이션 취약점                                                          |
| 점검 항목                                                                                                                                                                                                                      | 악성 파일 업로드 (Malicious File Upload)                                     |
| 점검 결과                                                                                                                                                                                                                      | 취약                                                                    |
| 취약 경로                                                                                                                                                                                                                      | upload.php                                                            |
| 취약 내용                                                                                                                                                                                                                      | 확장자 및 Content-Type 검증 없이 업로드 허용. shell.png.php 형태로 웹셸 업로드 및 명령어 실행 가능 |
| 확인 방법                                                                                                                                                                                                                      | PHP 웹셸을 이중 확장자(shell.png.php)로 업로드 후 URL 접근하여 명령어 실행 확인               |
| 대응 방안                                                                                                                                                                                                                      | 화이트리스트 기반 확장자 검증, 업로드 폴더 PHP 실행 권한 제거, 저장 시 파일명 무작위화                  |
| <p>▶ 대응 이유: 공격자가 이미지처럼 보이는 파일명(shell.png.php)으로 서버 제어 코드를 업로드합니다. 서버는 이것을 이미지 파일로 착각하고 저장합니다. 이후 공격자가 해당 파일의 주소에 접속하면 코드가 실행되어, 서버 파일 목록 조회·사용자 정보 탈취·다른 프로그램 설치까지 무엇이든 가능해집니다. 파일 하나의 업로드로 서버 전체가 공격자의 손에 넘어가는 상황입니다.</p> |                                                                       |

#### 4. 취약점 종합 요약

| 취약점               | 취약 경로                           | 점검결과 | 상태 |
|-------------------|---------------------------------|------|----|
| 코드 인젝션            | ping.php                        | 취약   | 완료 |
| SQL 인젝션           | login.php, post.php, search.php | 취약   | 완료 |
| 크로스사이트스크립트 (XSS)  | board.php, search.php           | 취약   | 완료 |
| 크로스사이트요청위조 (CSRF) | mypage.php                      | 취약   | 완료 |
| 악성 파일 업로드         | upload.php                      | 취약   | 완료 |

#### 5. 결론 및 권고사항

5가지 취약점 모두 확인되었으며, 특히 코드 인젝션, SQL 인젝션, 악성 파일 업로드는 서버 전체 장악으로 이어질 수 있어 즉각적인 조치가 필요합니다.

시큐어 코딩 가이드라인을 개발 단계부터 적용하고, 입력값 검증·Prepared Statement·출력 인코딩·CSRF 토큰·파일 실행 권한 제거를 포함한 종합 보안 대책 수립을 권고합니다.